GitHub Dorking Safe Guide

Educational Bug Bounty Series • Authorized Security Research Only

■ GitHub Dorking — Authorized Repository Auditing

Contributed by Cyber_Spy.404 | Bug Bounty Notes

Authorization rule: *Search repositories you own or are authorized to audit. If you discover a real secret in someone else's repository, do not use it, validate it against a service, or copy it into your notes.*

■ Executive Summary

The source HTML, *GitHub Dorking.html*, contains a very large list of search terms associated with API keys, cloud credentials, tokens, passwords, private keys, service accounts, deployment settings, and other configuration indicators. This guide keeps the source's purpose—finding accidental exposure during reconnaissance—but does not reproduce the full operational secret-search list or its many credential-shaped patterns.

■ Core Testing Methodology

1. Confirm the organization, repository, and account are in scope.
2. Prefer GitHub secret scanning, push protection, dependency/security alerts, and organization audit features.
3. Search your own repositories for configuration files, test fixtures, committed environment files, and secret-like placeholders.
4. Review commit history and forks within your authorized environment; deleted files can remain in history.
5. Never test a discovered token against a live API. Treat it as compromised and rotate/revoke it through the owner.
6. Store evidence as a redacted path, commit hash, and short context—not as the credential value.
7. Add prevention controls and verify that the secret is no longer active.

■ High-Value Tips & Edge Cases

- Search terms can identify likely locations but produce false positives (test fixtures, examples, documentation, and revoked credentials).
- A secret may be valid even if it looks unusual; do not validate it by using it.
- Removing a file from the latest commit does not remove it from Git history, forks, caches, or clones.
- Public client identifiers are not always secrets. Assess what privilege the value grants and follow vendor guidance.
- Search syntax and indexing change over time; confirm current behavior in GitHub's official documentation.
- The original file contains thousands of keyword/pattern entries. To keep this guide safe and maintainable, it is summarized by category rather than copied line by line.

■■ Educational Checklists & Safe Examples

Examples below are for **your own organization/repositories only**. Use a placeholder organization name.

```
org:YOUR-OWN-ORG filename:.env
org:YOUR-OWN-ORG filename:config
org:YOUR-OWN-ORG path:.github
org:YOUR-OWN-ORG "EXAMPLE_PLACEHOLDER_VALUE"
repo:YOUR-OWN-ORG/YOUR-OWN-REPO "TODO: rotate test credential"
```

These examples are intended to find configuration hygiene issues and placeholders, not to extract or use real credentials.

- [ ] Scope verified
- [ ] Secret-scanning alerts reviewed
- [ ] Environment/configuration files checked

- [ ] Commit history and forks considered
- [ ] Potential secrets redacted from evidence
- [ ] Exposed values revoked/rotated by the owner
- [ ] Push protection or pre-commit scanning enabled

■■ Mitigation & Remediation

Use a secrets manager or environment injection, never commit live secrets, enable secret scanning and push protection, apply least privilege and short token lifetimes, rotate exposed credentials immediately, and consider history rewriting only as a coordinated cleanup after revocation. History rewriting does not replace revocation.

■ Source Notes

Based on *GitHub Dorking.html*. The source includes many keyword families such as cloud-provider keys, API credentials, chat/service tokens, database passwords, private-key headers, CI/CD secrets, and environment variables. This document preserves the categories and workflow but omits the raw credential-finding catalogue and credential-like strings.

Educational use only. Test only systems you own or are explicitly authorized to assess. Confirm redistribution rights for source-derived material.